

Proposta de minicurso

Threat Hunting na Prática: da Hipótese à Detecção

1 Identificação

Título. Threat Hunting na Prática: da Hipótese à Detecção, com Estudos de Caso no Hikari.

Proponentes. Lourenço Alves Pereira Júnior, Sidnei Barbieri e Ágney Lopes Roth Ferraz (ITA).

Apresentadores. *(a definir entre os proponentes antes da submissão)*

Duração. 200 minutos, dos quais 110 de atividade prática.

Minibiografias. *(a completar: até cinco linhas por proponente, com formação, atuação e trabalhos relacionados ao tema)*

2 Dados gerais

2.1 Introdução

A detecção automática é uma aposta feita no passado: regras e modelos reconhecem o que já foi visto. O que escapa a essa aposta permanece no ambiente até que alguém vá procurá-lo. *Threat hunting*, ou caça a ameaças, é essa busca proativa, conduzida a partir de uma hipótese sobre como um adversário se comportaria, e não a partir de um alerta [Sqr16, LB16].

A necessidade é medida. Numa medição de quatro anos de alertas de rede num SOC em operação, analistas enfrentaram de 24 mil a 134 mil alertas por dia, dos quais apenas 0,01% associados a ataques verdadeiros, com investigações pós-ataque de 53 dias em média [YCW+24]; revisões recentes tratam a fadiga e a priorização de alertas como problema central da operação [TCNP25, JCNP25]. Do lado de quem caça, entrevistas com 22 caçadores experientes mostram que a atividade depende de conhecimento tácito e que a maior dificuldade é formular hipóteses [BRPR24], e um estudo com equipes que caçam para órgãos federais dos Estados Unidos relata que a maioria opera sem processo definido [MD24]. Ensinar caça, portanto, é ensinar a formular e refinar hipóteses sobre telemetria, sob pressão de tempo.

O diferencial desta proposta é o material prático: um cenário completo de uma operadora de telecomunicações fictícia, gerado de forma reproduzível, com 49.277 eventos no Elastic Common Schema e gabarito recalculado por código sobre o conjunto inteiro de eventos. Cada estudo de caso contém uma **isca deliberada**, uma rotina legítima que faz a consulta ingênua devolver a resposta errada, para que o participante aprenda a refinar a pergunta em vez de ordenar tabelas. O cenário é distribuído como pacote de desafios para a plataforma de caça gamificada Hikari, usada em competições nacionais do setor de telecomunicações, e também como notebooks Python que refazem os mesmos passos sem depender da plataforma.

2.2 Objetivos

O objetivo geral é ensinar o ciclo completo da caça, da hipótese à detecção derivada, com prática sobre telemetria realista. Ao final, espera-se que o participante seja capaz de:

- (i) distinguir caça de detecção e de resposta a incidentes, e situar as três nas funções do NIST CSF 2.0 [Nat24, NRSS25];
- (ii) escrever uma hipótese testável ancorada numa técnica do MITRE ATT&CK, conhecendo os limites da cobertura como métrica [SAM+18, VIR+24];

- (iii) investigar no Kibana com KQL e agregações, pivotando entre fontes de dados normalizadas no ECS;
- (iv) reconhecer iscas: identificar quando o topo de uma contagem é rotina legítima e trocar a pergunta;
- (v) converter a caçada em regra de detecção revisável, declarando o falso positivo esperado [Sig24, TMZA25];
- (vi) discutir criticamente os limites da automação da investigação e da própria caça [BJL⁺25, JBEM⁺25, GHWB23].

2.3 Perfil mínimo esperado

Estudantes de graduação e de pós-graduação em Computação e áreas afins, docentes, e profissionais de SOC e CSIRT. Não é exigida experiência prévia com SIEM: o curso começa pela primeira consulta KQL. Recomenda-se familiaridade com conceitos de rede e de sistemas operacionais. Para a parte em notebook, noções básicas de Python.

3 Estrutura prevista

Tabela 1: Estrutura prevista para o minicurso. Tempos em minutos.

Tópico	Pág.	Exp.	Prát.	Total	Bibliografia
Introdução	3	15	–	15	[Sqr16, BRPR24]
Conceitos e modelos de caça	7	25	–	25	[B ⁺ 23, Bet18, SAM ⁺ 18, Bia13]
Caça na literatura e na prática	8	25	–	25	[NPD23, YCW ⁺ 24, MEGV19, B JL ⁺ 25]
Ambiente, plataforma e cenário	5	10	10	20	[Ela24, Ken15, DAR20]
EC 1: da força bruta ao privilégio	8	10	25	35	[HDA ⁺ 21, TPY ⁺ 19, NWA ⁺ 20]
EC 2: o canal que respira	8	10	25	35	[HJS ⁺ 16, ONS24, LSC ⁺ 26]
EC 3: do mapa do diretório ao impacto	6	10	20	30	[KAM ⁺ 16, ZZW ⁺ 25, SHW ⁺ 25]
Da caçada à detecção, limites e tendências	5	15	–	15	[UHH ⁺ 24, HAL26, SEC ⁺ 24]
Total	50	120	80	200	

4 Detalhamento do conteúdo

Introdução. Por que a detecção não basta, o que a caça acrescenta e o que a literatura empírica mostra sobre quem caça. Apresentação do fio condutor do curso: a isca.

Conceitos e modelos de caça. Detecção, resposta e caça; o modelo de maturidade; os modelos de processo PEAK e TaHiTI; a cadeia de intrusão e o modelo diamante; ATT&CK e a Pirâmide da Dor, com as ressalvas medidas sobre cobertura; telemetria normalizada no ECS, KQL e agregações no Kibana; o conceito de pivô.

Caça na literatura e na prática. O que estudos empíricos observaram sobre a prática da caça e sobre a operação de SOCs; a linha de pesquisa que automatiza a investigação com grafos de proveniência e por que a adoção industrial é menor que os resultados publicados sugerem; engenharia de detecção e evasão; formação de defensores por competições e *cyber ranges*.

Ambiente, plataforma e cenário. A plataforma Hikari e o cenário Aurora Telecom; por que um cenário próprio em vez de uma base pública; reprodutibilidade e conferência do gabarito por código; o material das práticas (pacote de desafios e notebooks).

Estudos de caso. Três incidentes completos, cada um com hipótese, fontes de dados, investigação passo a passo, linha do tempo, resposta e detecção derivada, exercícios e a literatura relacionada. Cada caso tem uma isca verificada por código: se uma mudança no ruído fizer a consulta ingênua acertar, o conferidor reprova o cenário.

Da caçada à detecção, limites e tendências. O que os três casos têm em comum; como medir uma equipe de caça; ensinar caça com competições; limites do material; automação da investigação, modelos de linguagem e adversário adaptativo.

5 Atividades práticas

- **Prática 1 — a origem que entrou** (35 min). Cada participante investiga sozinho a força bruta na VPN e submete a resposta na plataforma; a discussão em conjunto expõe a isca (a sonda de monitoramento com senha vencida) e a troca de pergunta que resolve o caso.
- **Prática 2 — o canal que respira** (35 min). Em duplas, uma pessoa persegue o domínio do canal de comando e a outra o volume que sai; as duas linhas se encontram na mesma estação.
- **Prática 3 — do mapa do diretório ao impacto** (30 min). Cronometrada como um incidente: a turma parte do alerta de arquivos renomeados, reconstrói o que veio antes e escreve a regra de detecção derivada.

Todas as práticas têm caderno equivalente em **pandas** (`notebooks/caso1..3.ipynb`), com conferência automática das respostas contra o gabarito, para quem preferir o caderno ou quiser refazer o caso depois do curso.

6 Recursos necessários

Sala com projetor e acesso à internet. Cada participante usa o próprio notebook, com navegador. A instalação do Hikari com o cenário é disponibilizada pelos proponentes (nuvem) e pode ser subida localmente com Docker Compose por quem preferir. Os notebooks exigem apenas Python 3 e **pandas**. O material completo (cenário, gerador, gabarito conferido, pacote de desafios, notebooks e slides) é distribuído aos participantes.

7 Material e disponibilidade

O capítulo, os slides no formato 16:9, o gerador do cenário, o conferidor do gabarito, os testes e os notebooks ficam num repositório entregue aos participantes. O cenário é fictício e gerado de forma determinística: nenhum dado de competição real é usado, para que o minicurso possa anteceder uma prova sem entregar respostas.

Referências

- [B⁺23] David Bianco et al. The PEAK threat hunting framework. White paper, Splunk Inc., 2023.
- [Bet18] Betaalvereniging Nederland. TaHiTI: Targeted hunting integrating threat intelligence. Technical report, Betaalvereniging Nederland, 2018.
- [Bia13] David J. Bianco. The pyramid of pain. Enterprise Detection & Response (blog), 2013.

- [BJL⁺25] Tristan Bilot, Baoxiang Jiang, Zefeng Li, Nour El Madhoun, Khaldoun Al Agha, Anis Zouaoui, and Thomas Pasquier. Sometimes simpler is better: A comprehensive analysis of state-of-the-art provenance-based intrusion detection systems. In *34th USENIX Security Symposium*, pages 7193–7212. USENIX Association, 2025.
- [BRPR24] Priyanka Badva, Kopo M. Ramokapane, Eleonora Pantano, and Awais Rashid. Unveiling the hunter-gatherers: Exploring threat hunting practices and challenges in cyber defense. In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [DAR20] DARPA. Transparent computing engagement data releases, 2020.
- [Ela24] Elastic. Elastic common schema (ECS) reference. Documentação oficial, 2024.
- [GHWB23] Akul Goyal, Xueyuan Han, Gang Wang, and Adam Bates. Sometimes, you aren’t what you do: Mimicry attacks against provenance graph host intrusion detection systems. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2023.
- [HAL26] Kim Hammar, Tansu Alpcan, and Emil C. Lupu. Incident response planning using a lightweight large language model with reduced hallucination. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2026.
- [HDA⁺21] Grant Ho, Mayank Dhiman, Devdatta Akhawe, Vern Paxson, Stefan Savage, Geoffrey M. Voelker, and David A. Wagner. Hopper: Modeling and detecting lateral movement. In *30th USENIX Security Symposium*. USENIX Association, 2021.
- [HJS⁺16] Xin Hu, Jiyong Jang, Marc Ph. Stoecklin, Ting Wang, Douglas L. Schales, Dhilung Kirat, and Josyula R. Rao. BAYWATCH: Robust beaconing detection to identify infected hosts in large-scale enterprise networks. In *46th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, pages 479–490, 2016.
- [JBEM⁺25] Baoxiang Jiang, Tristan Bilot, Nour El Madhoun, Khaldoun Al Agha, Anis Zouaoui, Shahrear Iqbal, Xueyuan Han, and Thomas Pasquier. Orthrus: Achieving high quality of attribution in provenance-based intrusion detection systems. In *34th USENIX Security Symposium*. USENIX Association, 2025.
- [JCN25] Fatemeh Jalalvand, Mohan Baruwat Chhetri, Surya Nepal, and Cécile Paris. Alert prioritisation in security operations centres: A systematic survey on criteria and methods. *ACM Computing Surveys*, 57(2):42:1–42:36, 2025.
- [KAM⁺16] Amin Kharraz, Sajjad Arshad, Collin Mulliner, William Robertson, and Engin Kirda. UNVEIL: A large-scale, automated approach to detecting ransomware. In *25th USENIX Security Symposium*. USENIX Association, 2016.
- [Ken15] Alexander D. Kent. Comprehensive, multi-source cyber-security events. Los Alamos National Laboratory, 2015.
- [LB16] Robert M. Lee and David Bianco. Generating hypotheses for successful threat hunting. White paper, SANS Institute, 2016.
- [LSC⁺26] Daiping Liu, Danyu Sun, Zhenhua Chen, Shu Wang, and Zhou Li. Indicator of benignity: An industry view of false positive in malicious domain detection and its mitigation. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2026.
- [MD24] William P. Maxam, III and James C. Davis. An interview study on third-party cyber threat hunting processes in the U.S. department of homeland security. In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [MEGV19] Sadeq M. Milajerdi, Birhanu Eshete, Rigel Gjomemo, and V. N. Venkatakrishnan. POIROT: Aligning attack behavior with kernel audit records for cyber threat hunting. In *ACM SIGSAC Conference on Computer and Communications Security (CCS)*. ACM, 2019.
- [Nat24] National Institute of Standards and Technology. The NIST cybersecurity framework (CSF) 2.0. Technical Report CSWP 29, NIST, 2024.
- [NPD23] Boubakr Nour, Makan Pourzandi, and Mourad Debbabi. A survey on threat hunting in enterprise networks. *IEEE Communications Surveys & Tutorials*, 25(4):2299–2324, 2023.

- [NRSS25] Alex Nelson, Sanjay Rekhi, Murugiah Souppaya, and Karen Scarfone. Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile. Technical Report NIST SP 800-61r3, National Institute of Standards and Technology, 2025.
- [NWA⁺20] Amirreza Niakanlahiji, Jinpeng Wei, Md Rabbi Alam, Qingyang Wang, and Bei-Tseng Chu. ShadowMove: A stealthy lateral movement strategy. In *29th USENIX Security Symposium*. USENIX Association, 2020.
- [ONS24] Yarin Ozery, Asaf Nadler, and Asaf Shabtai. Information based heavy hitters for real-time DNS data exfiltration detection. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2024.
- [SAM⁺18] Blake E. Strom, Andy Applebaum, Doug P. Miller, Kathryn C. Nickels, Adam G. Pennington, and Cody B. Thomas. MITRE ATT&CK: Design and philosophy. Technical Report MTR180312, The MITRE Corporation, McLean, VA, 2018.
- [SEC⁺24] Daniel Schlette, Philip Empl, Marco Caselli, Thomas Schreck, and Günther Pernul. Do you play it by the books? A study on incident response playbooks and influencing factors. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 2024.
- [SHW⁺25] Armin Sarabi, Ziyuan Huang, Chenlan Wang, Tai Karir, and Mingyan Liu. The ransomware decade: The creation of a fine-grained dataset and a longitudinal study. In *34th USENIX Security Symposium*, pages 4799–4818. USENIX Association, 2025.
- [Sig24] SigmaHQ. Sigma: Generic signature format for SIEM systems. Repositório de código aberto, 2024.
- [Sqr16] Sqrrl Data. A framework for cyber threat hunting. White paper, Sqrrl Data, Inc., 2016.
- [TCNP25] Shahroz Tariq, Mohan Baruwat Chhetri, Surya Nepal, and Cécile Paris. Alert fatigue in security operations centres: Research challenges and opportunities. *ACM Computing Surveys*, 57(9):224:1–224:38, 2025.
- [TMZA25] Koen T. W. Teuwen, Tom Mulders, Emmanuele Zambon, and Luca Allodi. Ruling the unruly: Designing effective, low-noise network intrusion detection rules for security operations centers. In *ACM Asia Conference on Computer and Communications Security (AsiaCCS)*, pages 1428–1441. ACM, 2025.
- [TPY⁺19] Kurt Thomas, Jennifer Pullman, Kevin Yeo, Ananth Raghunathan, Patrick Gage Kelley, Luca Invernizzi, Borbala Benko, Tadek Pietraszek, Sarvar Patel, Dan Boneh, and Elie Bursztein. Protecting accounts from credential stuffing with password breach alerting. In *28th USENIX Security Symposium*. USENIX Association, 2019.
- [UHH⁺24] Rafael Uetz, Marco Herzog, Louis Hackländer, Simon Schwarz, and Martin Henze. You cannot escape me: Detecting evasions of SIEM rules in enterprise networks. In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [VIR⁺24] Apurva Virkud, Muhammad Adil Inam, Andy Riddle, Jason Liu, Gang Wang, and Adam Bates. How does endpoint detection use the MITRE ATT&CK framework? In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [YCW⁺24] Limin Yang, Zhi Chen, Chenkai Wang, Zhenning Zhang, Sushruth Booma, Phuong Cao, Constantin Adam, Alexander Withers, Zbigniew Kalbarczyk, Ravishankar K. Iyer, and Gang Wang. True attacks, attack attempts, or benign triggers? An empirical measurement of network alerts in a security operations center. In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [ZZW⁺25] Lingbo Zhao, Yuhui Zhang, Zhilu Wang, Fengkai Yuan, and Rui Hou. ERW-Radar: An adaptive detection system against evasive ransomware by contextual behavior detection and fine-grained content analysis. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2025.